



# UNIVERSIDAD TECNOLÓGICA DE QUERÉTARO

Ingeniería  
En Desarrollo y Gestión de Software

Seguridad en el desarrollo de aplicaciones

Grupo IDGS17

Nombre del alumno:  
Jovanny Guadalupe López Cebreros

Matricula:  
2023371119

Profesor:  
Gerardo Ramírez Villareal

Práctica SonarQube.

## Preguntas de Reflexión:

### ¿Qué diferencia hay entre un Security Hotspot y un Bug en SonarQube?

- Un Bug es un error claro en el código que causa un comportamiento inesperado o incorrecto.
- Un Security Hotspot es una pieza de código sensible a la seguridad que requiere una revisión manual, ya que no necesariamente es una vulnerabilidad inmediata, pero podría convertirse en una si no se implementan los controles adecuados.

### ¿Por qué es inseguro concatenar directamente el input del usuario en una query SQL? Explica el ataque con un ejemplo de payload.

- La concatenación directa permite la Inyección SQL, donde un atacante puede manipular la estructura de la consulta original para alterar su lógica.
- Un ejemplo de payload sería ingresar ' OR '1'='1 en un campo de usuario, lo que podría transformar una consulta como `SELECT * FROM users WHERE user = 'input'` en `SELECT * FROM users WHERE user = " OR '1'='1'`, logrando que la condición siempre sea verdadera y permitiendo acceso no autorizado.

### ¿Qué es el Code Coverage y por qué SonarQube lo considera relevante para la seguridad?

- El **Code Coverage** (cobertura de código) mide el porcentaje de tu código fuente que es ejecutado durante la ejecución de las pruebas automatizadas.
- Es relevante para la seguridad porque ayuda a garantizar que los componentes críticos y las funciones de validación de seguridad estén siendo probados; si una parte del código no tiene pruebas, existe un mayor riesgo de que contenga vulnerabilidades no detectadas.

### Si un colega sube el token de SonarQube a GitHub por error, ¿qué pasos seguirías para mitigar el riesgo?

- Lo primero es revocar el token inmediatamente desde la interfaz de SonarQube en la sección de seguridad de la cuenta de usuario.
- Luego, se debe eliminar el historial del repositorio de Git para borrar cualquier rastro del secreto y generar un nuevo token para actualizar las variables de entorno de forma segura.

### ¿Cómo integrarías SonarQube en un pipeline CI/CD de GitHub Actions? Describe los pasos a alto nivel.

- Configurar los secretos del repositorio en GitHub para almacenar el `SONAR_TOKEN` de forma segura.
- Definir un workflow en GitHub Actions que realice los pasos de: preparar el análisis (begin), ejecutar el build, correr los tests con cobertura y finalizar el análisis (end), utilizando siempre la variable de entorno protegida en lugar de exponer el token en el archivo YAML.